CYBER SECURITY

vulnerabilidades em aplicações web - Linux



1 - SUPPLY CHAIN ATTACK HITS ARCH LINUX COMMUNITY REPOSITORY

THE PROBLEM

Attack: Hijacking of orphaned packages in the AUR.

Tactic: Fake update with code injection.

GLOSSARY

- AUR: Arch User Repository.
- Arch Linux: Linux operating system (DIY Philosophy / Absolute hardware control).
- PKGBUILD: Package Build (Bash text script with installation instructions).

CODE ANALYSIS AND EXECUTION

The Trap: Inspecting the PKGBUILD

Open | PKGBUILD | Save

```
1  pkgname="hello-world"
2  pkgver="1.0.0"
3  pkgrel="1"
4  pkgdesc="Hello world in your terminal!"
5  arch=("x86_64")
6  source=("hello-world.sh")
7  sha512sums=("SKIP")
8
9  package() {
10   echo 'Hello to you!' > "${srcdir}/hello-world.sh"
11   mkdir -p "${pkgdir}/usr/bin"
12   cp "${srcdir}/hello-world.sh" "${pkgdir}/usr/bin/hello-world"
13   chmod +x "${pkgdir}/usr/bin/hello-world"
14 }
15
```

sh | Tab Width: 8 | Ln 15, Col 1 | INS

Inspection:

- Lines 1 and 2 (pkgname / pkgver): Facade variables.
- Line 6 (source): Attack vector.
- Lines 9 to 14 (package): Malicious execution.

The Trigger: Blind Compilation in the Terminal

```
hwittenborn@itsfoss:~$ ls
hello-world.sh  PKGBUILD
hwittenborn@itsfoss:~$ makepkg
==> Making package: hello-world 1.0.0-1 (Sat 08 May 2021 11:36:42 PM CDT)
==> Checking runtime dependencies...
==> Checking buildtime dependencies...
==> Retrieving sources...
  -> Found hello-world.sh
==> Validating source files with sha256sums...
    hello-world.sh ... Skipped
==> Extracting sources...
==> Starting prepare()...
==> Entering fakeroot environment...
==> Starting package()...
==> Tidying install...
  -> Removing libtool files...
  -> Purging unwanted files...
  -> Removing static library files...
  -> Stripping unneeded symbols from binaries and libraries...
  -> Compressing man and info pages...
==> Checking for packaging issues...
==> Creating package "hello-world"...
  -> Generating .PKGINFO file...
  -> Generating .BUILDINFO file...
  -> Generating .MTREE file...
  -> Compressing package...
==> Leaving fakeroot environment.
==> Finished making: hello-world 1.0.0-1 (Sat 08 May 2021 11:36:43 PM CDT)
hwittenborn@itsfoss:~$ ls
hello-world-1.0.0-1-x86_64.pkg.tar.zst  hello-world.sh  pkg  PKGBUILD  src
hwittenborn@itsfoss:~$
```

SOLUTIONS AND CONSEQUENCES

CONSEQUENCES

- Theft of credentials and security keys.
- Cryptojacking (hardware hijacking for crypto mining).
- Root Access (total system control).
- System lockdown (AUR blocked to contain damage).

USER SOLUTION

- Golden Rule: Mandatory reading of the PKGBUILD file before any installation.
- Source Verification: Check the origin of download links (source variable).
- Command Analysis: Review execution instructions (package function) against suspicious codes.
- End of Blind Compilation: Never execute the makepkg command automatically without prior review.

SYSTEM SOLUTION

- System-Side (Arch): Permanent Freezing Policy.
- Abandonment Rule: Immediate freezing.
- Inactivity Rule: Freezes after 18-24 months.
- Depreciation Timer: Countdown warning before freezing.
- Continuity: Mandatory Fork (new name).